

VULNERABILITY ASSESSMENT REPORT

Target: demo.testfire.net | Date: August
2026

AUGUST 2026

Prepared by
Yuvraj Singh



FINDINGS AND OVERALL RISK POSTURE

11 Findings

MEDIUM RISK

1. Missing Anti-CSRF Tokens

The login and other forms on this site don't include hidden security tokens to verify that a request is genuinely coming from the user. Without them, an attacker could potentially trick a logged-in user into unknowingly submitting an action on their behalf.

Fix: Add CSRF tokens to every form and validate them on the server side.

2. Content Security Policy Not Set

There's no policy in place restricting where scripts and content are allowed to load from. This makes it easier for an attacker to slip in malicious code if any other vulnerability gets exploited.

Fix: Set up a CSP header that only allows trusted, known sources.

3. Missing Anti-Clickjacking Header

The site doesn't stop other websites from embedding it in an invisible frame. That means someone could layer a fake button over the real page and trick users into clicking something they never intended to.

Fix: Add an X-Frame-Options header set to DENY or SAMEORIGIN.

4. Sub Resource Integrity (SRI) Attribute Missing

Scripts pulled in from external sources aren't being checked for tampering. If one of those external sources were ever compromised, malicious code could run on this site without warning.

Fix: Add SRI hashes to external script and stylesheet tags.

LOW RISK

5. Cookie Without SameSite Attribute

Cookies on this site can be sent along with requests from other websites, which raises the risk of cross-site attacks.

Fix: Set the SameSite attribute to Strict or Lax on all cookies.

6. Cross-Domain JavaScript Source File Inclusion

The site loads JavaScript from outside domains, which means it's placing trust in third parties it doesn't control.

Fix: Host scripts locally wherever possible, or lock things down with a CSP.

7. Server Leaks Version Info via "Server" Header

The server openly shares which software and version it's running (Apache-Coyote/1.1, in this case). That's useful information for an attacker looking for known exploits.

Fix: Configure the server to hide or obscure this version info.

8. X-Content-Type-Options Header Missing

Without this header, browsers can sometimes guess a file's type incorrectly, which opens the door for malicious files to run instead of being treated as harmless data.

Fix: Add the X-Content-Type-Options: nosniff header.

INFORMATIONAL

9. Information Disclosure – Suspicious Comments

While reviewing the page source, I found a leftover developer comment containing internal contact details — a name ("SiteOps") and phone number that were clearly never meant to be public.

Fix: Remove all developer and debug comments before pushing code to production.

10. Modern Web Application

Just a note — ZAP flagged that the site uses modern JavaScript frameworks. Nothing to fix here, purely informational.

11. Session Management Response Identified

ZAP identified how the app handles sessions (via cookies). Not a vulnerability on its own, but worth including in the report for context.